École Supérieure des Communications de Tunis

SUP'COM

PhantomOps

Hidden in plain sight. Unseen in transit.



DOCUMENT DES EXIGENCES

Besoins fonctionnels et exigences de sécurité (SRE)

Réalisé par :

Mohamed Fourat Boujdaria
Cheikh Brahim

Classe : INDP3 CySeD

Année Universitaire : 2026–2027

Sommaire

1 Introduction et périmètre **2**
1.1 Objet du document . . . 2
1.2 Documents de référence . . . 2
1.3 Périmètre et exclusions . . . 2
1.4 Hypothèses de confiance . . . 3
1.5 Conventions . . . 3

2 Besoins fonctionnels **3**
2.1 Exigences fonctionnelles et critères d'acceptation . . . 3
2.2 Règles de gestion et exigences de sécurité associées . . . 5
2.3 Exigences non fonctionnelles . . . 5

3 Justification de l'approche SRE choisie **6**
3.1 Approche retenue : les cas d'abus . . . 6
3.2 Application des objectifs fondamentaux du cours . . . 6
3.3 Comparaison avec les autres méthodologies du cours . . . 7
3.4 Mise en œuvre : de l'abus à l'exigence . . . 7

4 Actifs, adversaires et cas d'abus **8**
4.1 Actifs à protéger . . . 8
4.2 Adversaires . . . 9
4.3 Cas d'abus (abuse cases) . . . 9
4.4 Risques résiduels (exclusions du cahier) . . . 11

5 Exigences de sécurité **11**
5.1 Identification et authentification . . . 11
5.2 Autorisation (contrôle d'accès) . . . 12
5.3 Intégrité et confidentialité des données . . . 13
5.4 Non-répudiation . . . 14
5.5 Détection d'intrusions et audit . . . 15
5.6 Résilience et disponibilité . . . 15

6 Matrice de traçabilité **16**

7 Gestion des exigences et évolution **17**

Annexe A — Glossaire **18**

1 Introduction et périmètre

1.1 Objet du document

Ce document recense les besoins fonctionnels et les exigences de sécurité de PhantomOps, plateforme fictive d'échange sécurisé de rapports textuels entre les agences VOSTOK et LONGWEI, dont le cœur métier est la dissimulation de l'information (stéganographie, watermarking, fingerprinting). Il complète le cahier des charges déposé dans le même dépôt : il en reprend les identifiants (EF-xx, RG-xx) et les précise par des critères d'acceptation vérifiables.

Conformément à la demande de l'enseignant, il justifie l'approche SRE retenue (les cas d'abus) (§3), formalise les menaces du point de vue de l'attaquant (§4), recense en détail les exigences de sécurité (§5) et les relie aux tests (§6). Les exigences de sécurité sont identiques pour toutes les équipes ; seul le périmètre métier est dimensionné pour un binôme. Le document évolue avec le cours (§7).

1.2 Documents de référence

Cahier des charges PhantomOps (équipe 8) ; support du cours Sécurité applicative et consignes de la séance 1 ; OWASP ASVS et OWASP Top 10 ; NIST SP 800-63B (authentification) ; RFC 5280 (X.509, CRL), RFC 5869 (HKDF), RFC 6238 (TOTP), RFC 9106 (Argon2) ; spécification W3C Web Cryptography API.

1.3 Périmètre et exclusions

Dans le périmètre : un format porteur (PNG sans perte), un type de contenu (texte $\leq$ 16 Ko), un moteur de marquage à deux modes (filigrane d'origine, empreinte par destinataire et par livraison), une CA privée outillée avec révocation par CRL, une PWA/SPA et une API Jakarta EE 11 sur WildFly 42 / Java 25. Hors périmètre (cahier, §2.3) : robustesse à la compression, au redimensionnement et au recadrage ; résistance à la stéganalyse et à la collusion ; récupération de clé perdue ; CA maison, OCSP, multi-CA, HSM, application mobile native. Ces limites sont traitées comme risques résiduels explicites (§4.4).

1.4 Hypothèses de confiance

Réf.	Hypothèse
H-01	Le serveur est honnête mais curieux : il exécute le protocole mais peut chercher à lire les rapports. Il détient la clé de marquage et la clé de positionnement, et ne voit que des données chiffrées. Le serveur compromis reste un adversaire (AC-09, AC-13).
H-02	Le poste de l'agent et son navigateur (Chromium ou Firefox récent) ne sont pas compromis ; la clé non exportable peut être utilisée, mais pas copiée.
H-03	Le certificat racine embarqué dans le client est authentique (distribution initiale de confiance), et la clé racine de la CA n'est pas exposée.
H-04	Les agents comparent hors bande l'empreinte de leur clé à l'enrôlement (RG-08). Sans double approbation, un administrateur unique est un point de confiance partiel : il n'accède pas aux rapports (SR-12) mais ses actions sont tracées (SR-30).
H-05	Les canaux d'échange d'images (messagerie, partage de fichiers) sont observables et non maîtrisés, mais ne recompressent pas l'image : la traçabilité ne vaut que pour les fuites sans perte.

1.5 Conventions

EF exigence fonctionnelle ; RG règle de gestion ; NF exigence non fonctionnelle ; AC cas d'abus (*abuse case*) ; SR exigence de sécurité ; RR risque résiduel. Priorités MoSCoW : M (Must), S (Should), C (Could). Le niveau de risque d'un cas d'abus (Critique, Élevé, Moyen) croise gravité de l'impact sur la CIA et vraisemblance, évaluées qualitativement. Chaîne de traçabilité : AC → SR → chapitre du cours → test.

2 Besoins fonctionnels

2.1 Exigences fonctionnelles et critères d'acceptation

Les 17 fonctionnalités Must du cahier des charges sont reprises avec leur critère d'acceptation et les exigences de sécurité qui les encadrent. Les acteurs sont l'Agent (VOSTOK ou LONGWEI), l'Administrateur et, en Should, l'Auditeur (lecture seule du journal).

ID	Module	Fonctionnalité	Critère d'acceptation	SR liées
EF-01	Comptes et PKI	Invitation d'un agent par l'administrateur, activation du compte	Lien unique, valable 48 h ; compte « invité » → « actif » après choix du mot de passe ; aucune inscription ouverte	SR-01, 02, 09
EF-02	Comptes et PKI	Authentification et fermeture de session	Connexion identifiant + mot de passe ; la déconnexion invalide la session côté serveur ; verrouillage temporisé après 5 échecs	SR-03, 04, 05

ID	Module	Fonctionnalité	Critère d'acceptation	SR liées
EF-03	Comptes et PKI	Enrôlement : deux paires de clés non exportables (ECDSA, ECDH), demande de certificat, lot ECDH signé, approbation, émission	Clés générées dans le navigateur ; demande signée (preuve de possession) ; empreinte affichée à l'administrateur ; certificat X.509 émis par la CA privée après approbation seulement	SR-06, 07, 13, 19
EF-04	Comptes et PKI	Révocation, publication de la CRL, refus des certificats révoqués	La CRL est republiée après révocation ; tout envoi ou affichage impliquant ce certificat est refusé ; événement d'audit créé	SR-17, 30
EF-05	Comptes et PKI	Annuaire des certificats valides et des lots de clés de l'agence partenaire	Seuls les certificats valides de l'autre agence sont listés ; le client vérifie la signature de chaque lot	SR-11, 17, 19
EF-06	Échange	Rédaction d'un rapport et choix du destinataire	Texte $\leq$ 16 Ko (refus au-delà, côté client et serveur) ; destinataire obligatoirement de l'autre agence	SR-11, 25
EF-07	Échange	Chiffrement hybride et signature dans le navigateur	AES-256-GCM, clé issue d'ECDH éphémère et HKDF ; signature ECDSA ; aucune donnée en clair n'est émise	SR-15, 16, 18
EF-08	Échange	Dépôt d'une image porteuse PNG avec contrôles de validité	PNG vérifié par son contenu, $\leq$ 5 Mo, $\geq$ 1024×768, $\leq$ 16 Mpx ; refus avec message générique	SR-26, 37
EF-09	Échange	Dissimulation du paquet (LSB pseudo-aléatoire) avec contrôle de capacité	Paquet $\leq$ 25 % de la capacité utile ; extraction aller-retour sans perte ; $\leq$ 10 s pour 16 Ko dans 5 Mo	SR-21, 26, 37
EF-10	Échange	Application du filigrane et de l'empreinte à la livraison	Chaque livraison reçoit un UUIDv4, une empreinte unique et un identifiant de filigrane ; correspondance stockée avec code d'authentification	SR-20, 22
EF-11	Échange	Boîtes d'envoi et de réception, téléchargement par le destinataire	Seuls l'expéditeur et le destinataire désigné voient et téléchargent la livraison ; tout autre appelant $\rightarrow$ 404 uniforme	SR-10
EF-12	Échange	Extraction (serveur), déchiffrement et vérification de signature (navigateur)	Signature invalide $\rightarrow$ avertissement explicite ; clair affiché en mémoire uniquement ; ouverture journalisée	SR-15, 16, 27, 29
EF-13	Traçabilité	Vérification de fuite par l'administrateur	Image suspecte $\rightarrow$ extraction et authentification des marques $\rightarrow$ livraison désignée, ou « non concluant » si marque absente ou invalide	SR-12, 20, 22
EF-14	Traçabilité	Journal d'audit et consultation filtrée	Filtres par date, acteur, action, résultat ; aucun secret dans les entrées	SR-31, 35
EF-15	Administration	Gestion des utilisateurs (désactivation, rôles)	Désactivation : sessions invalidées immédiatement ; changement de rôle journalisé	SR-09, 12, 30
EF-16	PWA	Application installable	Manifeste valide ; service worker limité au shell, versionné ; aucune donnée d'API en cache	SR-24, 27

ID	Module	Fonctionnalité	Critère d'acceptation	SR liées
EF-17	Surveillance	Alertes de sécurité (règles de détection simples)	Quatre règles : échecs d'authentification, échecs d'extraction, révocation, demande de vérification de fuite ; alerte visible $\leq$ 60 s	SR-33

Should : second facteur TOTP (SR-08), journal d'audit chaîné par hachage (SR-32), tableau de bord de supervision, rôle Auditeur, pièce jointe unique $\leq$ 64 Ko, double approbation des enrôlements (SR-13). **Could** : expiration automatique des livraisons.

2.2 Règles de gestion et exigences de sécurité associées

Règle	Énoncé	SR liées
RG-01	Échanges inter-agences uniquement (VOSTOK $\leftrightarrow$ LONGWEI).	SR-11
RG-02	Destinataire avec certificat valide, non révoqué, émis par la CA du projet.	SR-17
RG-03, 04	Paquet $\leq$ 25 % de la capacité utile ; PNG vérifié par son contenu, $\leq$ 5 Mo, $\geq$ 1024×768, capacité $\geq$ 4 × la taille du paquet.	SR-26, 37
RG-05	UUIDv4 non devinable ; empreinte unique et identifiant de filigrane par livraison, correspondance intègre ; l'identifiant n'est jamais un jeton d'accès.	SR-10, 22
RG-06	Ni clé privée ni rapport en clair sur le serveur ; image porteuse d'origine supprimée après dissimulation.	SR-15, 27
RG-07	Comptes créés sur invitation uniquement.	SR-01
RG-08	Empreinte de clé journalisée à l'approbation, comparaison hors bande ; double approbation prévue (Should).	SR-07, 13

2.3 Exigences non fonctionnelles

ID	Catégorie	Exigence	Mesure
NF-01	Performance	Dissimulation d'un paquet de 16 Ko dans un PNG de 5 Mo en 10 s au plus.	Test chronométré en CI
NF-02	Compatibilité	Chromium et Firefox récents (WebCrypto, service worker).	Test précoce en S1
NF-03	Qualité	Tests unitaires du moteur (aller-retour, capacité, images invalides) ; couverture $\geq$ 80 % sur ce module.	Rapport de couverture en CI
NF-04	Maintenabilité	Build reproductible, README d'installation, intégration continue à chaque pull request.	Pipeline CI vert
NF-05	Ergonomie	Parcours d'envoi en 5 étapes au plus.	Revue du parcours

3 Justification de l'approche SRE choisie

3.1 Approche retenue : les cas d'abus

L'enseignant demande de choisir une approche d'ingénierie des exigences de sécurité (SRE) et de la justifier. L'équipe retient les **cas d'abus** (*abuse cases*, ou cas de mésusage), prolongés par des cas d'utilisation de sécurité. Un cas d'abus est un cas d'utilisation inversé : il décrit ce qu'un attaquant tente de faire contre le système et que celui-ci ne doit pas permettre. À chaque cas d'abus répond un cas d'utilisation de sécurité, formulé ici comme une exigence SR-xx mesurable et testable. Les autres méthodologies du cours sont comparées au §3.3 et non retenues.

Ce choix est justifié par quatre raisons propres à PhantomOps :

Raison	Justification
Système adversarial	La stéganographie, le watermarking et le fingerprinting n'ont de valeur que face à un attaquant qui cherche à détecter, effacer ou forger les marques. Le cas d'abus exprime exactement ce point de vue.
Proportionnée à un binôme	Aucun outillage ni atelier avec des parties prenantes : les cas d'abus s'écrivent en texte et se suivent dans GitHub Issues, dans les quatre semaines de réalisation.
Exigences précises et testables	Chaque cas d'abus donne une ou plusieurs exigences avec mécanisme, seuil et vérification, ce qui évite les listes génériques.
Traçabilité directe	Chaîne AC → SR → chapitre → test (§6) : aucune exigence sans cas d'abus, aucun cas d'abus sans exigence, ce qui rend la couverture vérifiable.

3.2 Application des objectifs fondamentaux du cours

Objectif	Application dans PhantomOps
Shift-Left	Cas d'abus et exigences rédigés avant le code (S0), puis révisés à chaque chapitre. Chaque SR Must a une vérification planifiée dans les semaines S1 à S4 du cahier.
Perspective de l'attaquant	25 cas d'abus (§4.3) écrits du point de vue de 4 adversaires (§4.2) ; chaque exigence de sécurité répond à au moins un cas d'abus.
Triptyque CIA	Chaque actif est étiqueté C, I ou D (§4.1). Confidentialité (SR-15), intégrité (SR-16, 20, 22) et disponibilité (SR-36 à 38) sont exigées explicitement, avec leur vérification.
Exigences précises, non génériques	Format SMART : mécanisme, valeur, seuil et vérification. Exemple : « utiliser des mots de passe » devient SR-02 et SR-03 (Argon2id, $\geq$ 12 caractères, verrouillage au 5e échec).

3.3 Comparaison avec les autres méthodologies du cours

Méthodologie	Décision	Justification
Cas de mésusage et d'abus	Retenue	Voir §3.1.
SQUARE (9 étapes)	Non retenue	Processus complet en 9 étapes, avec ateliers et arbitrage entre parties prenantes : trop lourd pour un binôme et quatre semaines.
Récits d'abus et de sécurité	Non retenue	Pratique de gestion de backlog qui suppose les abus déjà identifiés ; elle ne les produit pas. Le suivi dans GitHub Issues suffit.
Arbres d'attaque, modélisation des menaces	Non retenue	Décomposent l'attaque d'un actif à la fois ; ne donnent pas directement un ensemble d'exigences testables couvrant tout le système.
UMLsec, SecureUML	Non retenue	Suppose une chaîne d'ingénierie dirigée par les modèles, disproportionnée pour ce projet.
SERA	Non retenue	Orientée contextes opérationnels et chaînes de mission, peu adaptée à un système académique au périmètre réduit.
OCTAVE	Non retenue	Évaluation organisationnelle des risques et des actifs, trop lourde pour le projet (déjà écartée dans le cahier, §5.1).

3.4 Mise en œuvre : de l'abus à l'exigence

1. Identifier les actifs et les adversaires (§4.1, §4.2).
2. Rédiger les cas d'abus AC-xx du point de vue de l'attaquant (§4.3).
3. Pour chaque cas d'abus, définir le cas d'utilisation de sécurité : une ou plusieurs exigences SR-xx SMART (§5), priorisées MoSCoW et par niveau de risque.
4. Vérifier chaque exigence par un test (§6) et suivre l'avancement dans GitHub Issues ; chaque SR est référencée dans le code et les tests.

Exemple de fiche, du cas d'abus à l'exigence et au test :

Cas d'abus	AC-06 : énumérer ou deviner des identifiants de livraison pour télécharger les images d'autres agents (IDOR).
Acteur, niveau	Agent malveillant (compte et certificat valides) ; niveau critique.
Scénario d'attaque	L'agent ouvre l'une de ses livraisons et relève son identifiant ; il modifie cet identifiant dans la requête de téléchargement ou en essaie d'autres ; si le serveur ne contrôle que l'existence de l'identifiant, il obtient l'image d'un autre agent.
Impact	Atteinte à la confidentialité des livraisons (images, métadonnées, existence d'échanges inter-agences) ; le paquet reste chiffré (SR-15).
Cas d'utilisation de sécurité	SR-10 : chaque opération vérifie côté serveur que l'appelant est l'expéditeur ou le destinataire désigné, sinon réponse 404 identique à celle d'un identifiant inexistant ; l'UUIDv4 n'est jamais un jeton d'accès (RG-05).
Vérification	Test IDOR : un agent tiers demande la livraison d'un autre → 404 indiscernable ; événement d'audit créé (SR-31).

Définition de « terminé » : code relu par l'autre membre, tests (dont les tests d'abus associés) écrits et verts en intégration continue, exigences liées vérifiées, documentation à jour.

4 Actifs, adversaires et cas d'abus

4.1 Actifs à protéger

Actif	CIA	Emplacement et protection principale
Rapports	C, I	Clair uniquement dans le navigateur du destinataire ; ailleurs chiffré et dissimulé dans un PNG
Clés privées des agents (ECDSA, ECDH)	C	CryptoKey non exportable dans le navigateur ; jamais transmise au serveur
Clés de la CA privée	C, I	step-ca en conteneur ; clé racine hors dépôt
Clé de marquage et clé de positionnement	C, I	Serveur (secrets de déploiement) ; la clé de positionnement n'est pas une clé de confidentialité
Journal d'audit	I	PostgreSQL, insertion seule ; chaînage par hachage en Should
Comptes et sessions	C, I	PostgreSQL (condensats Argon2id), cookies de session
Service d'échange	D	WildFly, PostgreSQL, moteur de dissimulation

4.2 Adversaires

Adversaire	Capacités	Objectifs	Cas d'abus principaux
Attaquant externe	Observe et interagit avec l'API ; aucun compte au départ	Prendre un compte, lire un rapport, saturer le service	AC-01, 02, 03, 15, 17, 18, 22, 23, 24
Agent malveillant	Compte et certificat valides ; peut rediffuser une image reçue	Fuiter sans être identifié, usurper, accéder aux livraisons d'autrui	AC-04 à 07, 12, 14, 19, 20, 25
Administrateur curieux	Droits d'administration (comptes, certificats, alertes)	Lire les rapports, émettre un certificat pour espionner, masquer ses actions	AC-08, 10, 21
Serveur compromis	Contrôle de WildFly, de la base et des images ; voit les données chiffrées	Lire, substituer des clés, falsifier des marques, servir du code piégé	AC-09, 10, 11, 13, 16

4.3 Cas d'abus (abuse cases)

Les 25 cas d'abus ci-dessous sont rédigés du point de vue de l'attaquant. Le niveau de risque croise la gravité de l'impact et la vraisemblance. Chaque cas d'abus est traité par au moins une exigence de sécurité (§5, §6).

ID	Cas d'abus (point de vue de l'attaquant)	Acteur	Niveau
AC-01	Se créer un compte sans invitation, ou rejouer / forger un jeton d'invitation pour obtenir l'accès	Externe	Élevé
AC-02	Deviner ou rejouer des mots de passe (force brute, bourrage d'identifiants) et énumérer les comptes existants	Externe	Élevé
AC-03	Voler, fixer ou rejouer une session ; forcer une action par CSRF	Externe	Élevé
AC-04	S'enrôler sous une fausse identité (clé ou certificat usurpé, sans preuve de possession) pour recevoir ou signer à la place d'un agent	Agent malveillant	Critique
AC-05	Atteindre les fonctions d'administration avec un compte d'agent, ou élever son propre rôle	Agent malveillant	Élevé
AC-06	Énumérer ou deviner des identifiants de livraison pour télécharger les images d'autres agents (IDOR)	Agent malveillant	Critique
AC-07	Contourner la règle inter-agences ou viser un destinataire invalide en appelant l'API directement	Agent malveillant	Élevé
AC-08	Utiliser les droits d'administration pour lire des rapports, s'auto-approuver ou faire émettre un certificat afin d'espionner	Administrateur curieux	Élevé
AC-09	Lire les rapports ou récupérer des clés privées dans la base, les journaux, les images ou la mémoire du serveur	Serveur curieux ou compromis	Critique
AC-10	Modifier ou effacer des entrées du journal d'audit pour masquer des actions	Administrateur, serveur compromis	Élevé

ID	Cas d'abus (point de vue de l'attaquant)	Acteur	Niveau
AC-11	Modifier le texte chiffré, rejouer un paquet ou le substituer à un autre destinataire	Externe, serveur compromis	Élevé
AC-12	Faire accepter un certificat révoqué ou expiré, ou bloquer l'accès à la CRL pour l'ignorer	Agent malveillant	Élevé
AC-13	Substituer la clé ECDH d'un destinataire dans l'annuaire pour intercepter ses rapports (homme du milieu)	Serveur compromis	Critique
AC-14	Forger un filigrane ou une empreinte, ou modifier leur correspondance en base, pour incriminer un tiers ou s'innocenter	Agent, serveur compromis	Élevé
AC-15	Détecter puis extraire le message caché d'une image interceptée	Externe	Moyen
AC-16	Injecter du code dans le client (XSS, ressource tierce, service worker piégé) pour voler clés ou clairs	Externe, serveur compromis	Critique
AC-17	Injecter des charges (SQL, XSS, CRLF, en-têtes) via le texte, les champs ou les noms de fichier	Externe	Élevé
AC-18	Soumettre une image piégée (pixel flood, PNG tronqué ou polyglotte) pour saturer ou compromettre le moteur	Externe, agent	Élevé
AC-19	Nier avoir envoyé ou reçu un rapport	Agent malveillant	Moyen
AC-20	Effacer le filigrane ou l'empreinte (recompression, recadrage) ou comparer plusieurs copies (collusion) pour fuir sans être identifié	Agent malveillant	Moyen
AC-21	Agir sans déclencher d'alerte : événements non journalisés, fausses lignes injectées dans le journal	Tous	Moyen
AC-22	Exploiter les messages d'erreur et traces (versions, SQL, existence de comptes) pour préparer une attaque	Externe	Moyen
AC-23	Saturer le service (rafales d'envois, requêtes volumineuses, remplissage du stockage)	Externe, agent	Élevé
AC-24	Exploiter un composant vulnérable, une configuration faible (console WildFly, conteneur) ou des secrets exposés	Externe	Élevé
AC-25	Récupérer clés ou clairs sur le poste de l'agent (cache, stockage navigateur, export de clé)	Agent, externe	Élevé

4.4 Risques résiduels (exclusions du cahier)

ID	Risque	Atténuation et décision
RR-01	Compression JPEG, redimensionnement, recadrage : marques et message détruits	Traçabilité limitée aux fuites sans perte ; résultat « non concluant » explicite (SR-20). Accepté.
RR-02	Stéganalyse statistique : l'image peut être détectée comme porteuse	Positions pseudo-aléatoires, charge $\leq 25\,\%$ (SR-21, 26) ; la confidentialité repose sur le chiffrement de bout en bout (SR-15). Accepté.
RR-03	Collusion (comparaison de plusieurs copies)	Empreinte unique par livraison, journal des livraisons (SR-22, 31) ; traité par AC-20. Accepté.
RR-04	Divulgation du clair par son destinataire	Aucune marque dans le texte ; l'audit établit l'ouverture (SR-29). Accepté.
RR-05	Serveur servant un code client malveillant (limite du chiffrement de bout en bout web)	CSP stricte, SRI, service worker versionné (SR-24). Atténué.
RR-06	Perte d'une clé privée	Nouvel enrôlement ; anciens rapports illisibles (pas de séquestre). Accepté.

5 Exigences de sécurité

Les 40 exigences ci-dessous suivent les six types du cours. Chacune est mesurable, rattachée à au moins un cas d'abus (colonne AC, issue de la matrice §6) et assortie d'un critère de vérification. P = priorité MoSCoW. Elles s'échelonnent sur le planning du cahier (S1 : authentification, sessions, squelette ; S2 : chiffrement, moteur ; S3 : PKI, autorisation, livraison ; S4 : audit, tests, déploiement).

Catégorie	Must	Should	Total
Identification et authentification	7	1	8
Autorisation (contrôle d'accès)	5	1	6
Intégrité et confidentialité des données	13	0	13
Non-répudiation	3	0	3
Détection d'intrusions et audit	4	1	5
Résilience et disponibilité	4	1	5
Total	**36**	**4**	**40**

5.1 Identification et authentification

ID	Exigence mesurable	P	AC	Vérification
SR-01	Aucun compte sans invitation : jeton d'invitation $\geq$ 128 bits aléatoires, à usage unique, expirant sous 48 h ; aucune route d'inscription ouverte.	M	01	Jeton rejoué, expiré ou forgé $\rightarrow$ refus ; inventaire des routes sans inscription ouverte.
SR-02	Mots de passe hachés en Argon2id ($\geq$ 19 Mio, 2 itérations, 1 voie) avec sel unique ; longueur $\geq$ 12 caractères ; refus des mots de passe courants (liste $\geq$ 10 000 entrées).	M	02	Test unitaire du hachage ; revue de configuration ; mot de passe faible refusé.
SR-03	Après 5 échecs consécutifs en 15 min : verrouillage temporisé croissant (1 min, doublé jusqu'à 30 min) par compte et par IP ; réponse et temps de réponse identiques que le compte existe ou non.	M	02	6e tentative refusée ; comparaison statistique des réponses compte valide / inexistant.
SR-04	Session par cookie HttpOnly, Secure, SameSite=Strict, identifiant $\geq$ 128 bits ; expiration après 15 min d'inactivité et 8 h au plus ; régénération à la connexion ; invalidation serveur à la déconnexion ou à la désactivation du compte.	M	03	Cookie rejoué après déconnexion $\rightarrow$ 401 ; inspection des attributs du cookie.
SR-05	Toute requête modifiant l'état exige un jeton anti-CSRF (ou en-tête personnalisé vérifié), en plus de SameSite.	M	03	Requête cross-origin sans jeton $\rightarrow$ 403.
SR-06	Les clés ECDSA et ECDH sont générées dans le navigateur avec extractable = false ; l'enrôlement exige une preuve de possession (demande signée par la clé privée) ; aucun certificat n'est émis sans approbation de l'administrateur.	M	04, 25	exportKey échoue ; demande sans preuve rejetée ; émission sans approbation impossible.
SR-07	À l'approbation, l'empreinte SHA-256 de la clé publique est affichée à l'administrateur, journalisée et consultable par l'agent pour comparaison hors bande (RG-08).	M	04, 13	Empreinte affichée = empreinte journalisée = empreinte du certificat émis.
SR-08	Second facteur TOTP (RFC 6238) obligatoire pour le rôle Administrateur ; secret TOTP chiffré au repos.	S	02, 05	Connexion administrateur sans code valide refusée ; secret absent en clair en base.

5.2 Autorisation (contrôle d'accès)

ID	Exigence mesurable	P	AC	Vérification
SR-09	Contrôle d'accès par rôle avec refus par défaut : chaque ressource REST est protégée (Jakarta Security, @RolesAllowed) ; matrice rôle $\times$ endpoint versionnée dans le dépôt.	M	01, 05	Test automatisé sur chaque endpoint (rôle non autorisé $\rightarrow$ 403) ; test d'architecture détectant tout endpoint non annoté.
SR-10	Toute opération sur une livraison vérifie côté serveur que l'appelant en est l'expéditeur ou le destinataire désigné ; sinon réponse 404 identique à celle d'un identifiant inexistant ; l'UUIDv4 n'est jamais un jeton d'accès.	M	06	Test IDOR : agent tiers $\rightarrow$ 404 ; réponses indiscernables.

ID	Exigence mesurable	P	AC	Vérification
SR-11	Le serveur refuse tout envoi dont l'expéditeur et le destinataire appartiennent à la même agence (RG-01), quels que soient les contrôles du client.	M	07	Appel API direct VOSTOK → VOSTOK refusé (403) et audité.
SR-12	L'administrateur n'a accès ni aux rapports, ni aux paquets, ni aux images livrées (hors image suspecte qu'il soumet) ; il ne peut approuver son propre enrôlement.	M	05, 08	Administrateur sur une livraison → 403 ; auto-approbation refusée.
SR-13	Double approbation : un enrôlement exige l'accord de deux administrateurs distincts avant émission du certificat.	S	04, 08	Une seule approbation → aucun certificat émis ; même administrateur deux fois → refus.
SR-14	Le compte PostgreSQL de l'application n'a aucun droit DDL ; sur la table d'audit, seuls INSERT et SELECT sont accordés (UPDATE, DELETE, TRUNCATE interdits).	M	10	UPDATE sur l'audit refusé ; revue des GRANT dans le script de déploiement.

5.3 Intégrité et confidentialité des données

ID	Exigence mesurable	P	AC	Vérification
SR-15	Les rapports sont chiffrés dans le navigateur en AES-256-GCM, clé dérivée par ECDH (clé éphémère de l'expéditeur) puis HKDF-SHA-256 ; le serveur ne reçoit jamais de clair ni de clé privée.	M	09	Texte canari recherché dans le trafic, la base, les journaux et l'image : 0 occurrence.
SR-16	Le paquet est signé en ECDSA P-256 / SHA-256 ; la signature couvre texte chiffré, clé éphémère, nonce et identité du destinataire ; vérifiée avant affichage ; échec → avertissement explicite, rapport non présenté comme authentique.	M	11, 19	Bit modifié, destinataire changé, signature d'un tiers → rejet.
SR-17	Avant chiffrement et avant affichage, la chaîne est validée jusqu'à la racine embarquée et la CRL consultée ; certificat expiré, révoqué ou CRL périmée (nextUpdate dépassé) → refus (échec fermé) ; le serveur applique les mêmes contrôles (CertPathValidator).	M	04, 07, 12	Certificat révoqué, expiré, chaîne tronquée, CRL périmée → refus côté client et serveur.
SR-18	Nonce AES-GCM de 96 bits aléatoire et unique par message ; paire ECDH éphémère à usage unique ; aucune réutilisation de clé de session.	M	11	10 000 chiffrements : aucun nonce dupliqué ; clé éphémère distincte à chaque envoi.
SR-19	Le lot de clés ECDH d'un agent est signé par sa clé d'identité ; le client vérifie cette signature et le certificat avant tout usage ; clé non signée ou signée par un autre → refus.	M	13	Serveur simulé substituant une clé ECDH → rejet côté client.

ID	Exigence mesurable	P	AC	Vérification
SR-20	Filigrane et empreinte portent un identifiant et un HMAC-SHA256 tronqué à $\geq$ 64 bits, calculé avec la clé de marquage serveur ($\geq$ 256 bits) ; vérification en temps constant ; marque absente ou invalide $\rightarrow$ « non concluant ».	M	14, 20	Marque forgée sans clé $\rightarrow$ non concluant ; marque authentique $\rightarrow$ livraison désignée ; revue du temps constant.
SR-21	Les positions LSB sont tirées d'un générateur pseudo-aléatoire cryptographique initialisé par une clé de positionnement dérivée par livraison (HKDF depuis un secret serveur et l'identifiant de livraison) ; la confidentialité n'en dépend pas.	M	15	Extraction avec une mauvaise clé $\rightarrow$ échec ; deux livraisons de la même image $\rightarrow$ positions différentes.
SR-22	La correspondance livraison $\leftrightarrow$ empreinte $\leftrightarrow$ identifiant de filigrane est protégée par un code d'authentification (HMAC) sur l'enregistrement ; toute modification en base est détectée à la lecture et journalisée.	M	14, 20	Modification directe en base $\rightarrow$ alerte d'intégrité et refus d'identifier.
SR-23	Aucun secret (clés de marquage et de positionnement, clé de CA, mots de passe) dans le dépôt, les images Docker ou les journaux ; injection par secrets Docker ou variables d'environnement ; procédure de rotation documentée.	M	24	Scan de secrets en CI ; inspection des images et des journaux.
SR-24	HTTPS obligatoire (TLS 1.3 de préférence, 1.2 au minimum) avec HSTS ; CSP stricte (default-src 'self', aucun script inline), SRI sur toute ressource tierce, X-Content-Type-Options, Referrer-Policy ; service worker versionné.	M	03, 16	Scan des en-têtes en CI ; script inline injecté bloqué par la CSP.
SR-25	Toute entrée est validée côté serveur (Bean Validation, listes blanches) : texte $\leq$ 16 Ko, formats d'identifiants ; requêtes JPA paramétrées ; échappement systématique en sortie.	M	16, 17	Analyse statique ; charges XSS / SQL / CRLF rejetées ou neutralisées.
SR-26	Image porteuse vérifiée par son contenu (signature PNG et décodage, jamais l'extension) ; $\leq$ 5 Mo ; $\geq$ 1024×768 et $\leq$ 16 mégapixels, dimensions lues dans l'en-tête avant décodage ; paquet $\leq$ 25 % de la capacité utile (RG-03, RG-04) ; erreur générique en cas de rejet.	M	18	PNG de 100 000 × 100 000 px, PNG tronqué, polyglotte, fichier renommé : rejet $<$ 2 s sans saturation mémoire.
SR-27	Aucun clair ni clé privée persisté : le clair reste en mémoire du navigateur ; le service worker ne met en cache que le shell ; l'image d'origine est supprimée après dissimulation ; seules les données personnelles nécessaires (identifiant, agence, rôle) sont stockées.	M	09, 16, 25	Inspection d'IndexedDB, Cache, localStorage et du disque serveur après un cycle complet.

5.4 Non-répudiation

ID	Exigence mesurable	P	AC	Vérification
SR-28	Le paquet signé et la chaîne de certificats de l'expéditeur sont conservés avec la livraison ; la signature est vérifiable par un tiers avec la racine de la CA, sans l'aide de l'expéditeur.	M	19	Vérification hors ligne d'une livraison archivée avec un script indépendant.
SR-29	L'ouverture d'une livraison et l'extraction du paquet sont journalisées (acteur, horodatage UTC, identifiant, résultat) ; ces événements établissent que le destinataire a pu lire le rapport.	M	19	Chaque ouverture crée exactement un événement d'audit.
SR-30	Approbation d'enrôlement, émission, révocation et changement de rôle sont journalisés avec l'administrateur auteur, le numéro de série et l'empreinte de clé.	M	04, 08	Chaque action d'administration produit un événement attribuable à un auteur.

5.5 Détection d'intrusions et audit

ID	Exigence mesurable	P	AC	Vérification
SR-31	Les événements de sécurité sont journalisés : authentification, invitation, enrôlement, émission, révocation, envoi, ouverture, extraction, vérification de fuite, refus d'autorisation, changement de rôle ; chaque entrée porte horodatage UTC, acteur, action, objet, résultat ; consultation filtrée réservée à Administrateur et Auditeur.	M	08, 10, 21	Scénario complet rejoué : couverture de la liste d'événements par checklist.
SR-32	Chaque entrée inclut le condensat SHA-256 de la précédente (chaînage) ; vérification de la chaîne chaque nuit et à la demande ; rupture → alerte.	S	10	Suppression ou modification d'une ligne → rupture détectée.
SR-33	Alerte à l'administrateur en ≤ 60 s après : $\geq$ 5 échecs d'authentification en 10 min (compte ou IP) ; ≥ 3 échecs d'extraction en 10 min ; toute révocation ; toute vérification de fuite ; toute rupture d'intégrité.	M	02, 21	Un scénario par règle ; mesure du délai d'alerte.
SR-34	Le client ne reçoit que des erreurs génériques accompagnées d'un identifiant de corrélation ; aucune trace de pile, version ou détail SQL ; pages d'erreur WildFly personnalisées ; détails dans les journaux serveur seulement.	M	22	Entrées invalides et extraction ratée → messages uniformes ; scan des réponses.
SR-35	Les journaux ne contiennent ni mot de passe, ni jeton, ni clé, ni clair ; les données issues de l'utilisateur sont neutralisées (CR / LF) avant journalisation.	M	17, 21	Canari et charge CRLF : absents ou neutralisés dans les journaux.

5.6 Résilience et disponibilité

ID	Exigence mesurable	P	AC	Vérification
SR-36	Limitation de débit : ≤ 10 tentatives d'authentification par minute et par IP, ≤ 20 envois par heure et par agent ; taille de requête plafonnée à 6 Mo dans WildFly ; quota de stockage par agent.	M	23	Test de charge : dépassement $\rightarrow$ 429 ; requête de 50 Mo rejetée avant lecture complète.
SR-37	Le moteur d'information hiding s'exécute avec temps (10 s) et mémoire plafonnés, en traitement borné ; le parseur d'images est fuzzé ($\geq 10\,000$ entrées malformées par campagne) sans arrêt de l'API.	M	18, 23	Campagne de fuzzing en CI ; délai dépassé $\rightarrow$ erreur contrôlée.
SR-38	Sauvegarde quotidienne chiffrée de PostgreSQL et du stockage d'images ; restauration testée au moins une fois (RPO $\leq$ 24 h, RTO $\leq$ 4 h).	S	10, 23	Procédure de restauration exécutée et chronométrée.
SR-39	Déploiement durci : console d'administration WildFly non exposée, conteneurs non root, images à versions épinglées, seul HTTPS exposé.	M	24	Checklist de durcissement ; scan d'image en CI ; scan de ports du déploiement.
SR-40	Dépendances inventoriées et analysées à chaque pull request (analyse de composition logicielle) ; analyse statique du code ; aucune vulnérabilité critique ouverte à la livraison.	M	24	Rapport CI bloquant ; exceptions justifiées et datées.

6 Matrice de traçabilité

Chaîne AC $\rightarrow$ SR $\rightarrow$ chapitre du cours $\rightarrow$ test. Chapitres : 2 méthodologies et spécification ; 3 confidentialité, intégrité, disponibilité ; 4 authentification, autorisation, informations privées ; 5 journalisation et gestion des erreurs ; 6 tests de sécurité ; 7 déploiement et maintenance. Les identifiants SR sont référencés dans le code et les tests.

AC	SR	EF	Chap.	Test de vérification
AC-01	SR-01, 09	EF-01	4	Test API : inscription ouverte, jeton rejoué, expiré ou forgé
AC-02	SR-02, 03, 08, 33	EF-02, 17	4	Force brute scriptée ; comparaison des réponses compte valide / inexistant
AC-03	SR-04, 05, 24	EF-02	3, 4	Rejeu de cookie après déconnexion ; requête cross-origin sans jeton
AC-04	SR-06, 07, 13, 17, 30	EF-03, 04	4	Enrôlement sans preuve de possession, auto-approbation, fausse identité
AC-05	SR-08, 09, 12	EF-15	4	Matrice rôle $\times$ endpoint : tout rôle non autorisé $\rightarrow$ 403
AC-06	SR-10	EF-11	4	Agent B sur une livraison de A $\rightarrow$ 404 indiscernable d'un identifiant inexistant
AC-07	SR-11, 17	EF-05, 06	4	Appel API direct VOSTOK $\rightarrow$ VOSTOK ; certificat d'une même agence
AC-08	SR-12, 13, 30, 31	EF-03, 15	4, 5	Administrateur sur une livraison $\rightarrow$ 403 ; attribution de chaque action admin
AC-09	SR-15, 27	EF-07, 12	3	Texte canari absent du trafic, de la base, des journaux et de l'image

AC	SR	EF	Chap.	Test de vérification
AC-10	SR-14, 31, 32, 38	EF-14	5	UPDATE / DELETE sur l'audit refusés ; rupture de chaîne détectée
AC-11	SR-16, 18	EF-07, 12	3	Bit modifié, destinataire changé, nonce réutilisé → rejet
AC-12	SR-17	EF-04	3, 4	Certificat révoqué, expiré, chaîne tronquée, CRL périmée → refus
AC-13	SR-07, 19	EF-03, 05	3	Serveur simulé substituant une clé ECDH → rejet côté client
AC-14	SR-20, 22	EF-10, 13	3	Marque forgée sans clé ; modification directe en base détectée
AC-15	SR-21	EF-09	3	Extraction avec une mauvaise clé ; positions distinctes par livraison
AC-16	SR-24, 25, 27	EF-16	3, 6	Charge XSS bloquée par la CSP ; vérification SRI ; revue du service worker
AC-17	SR-25, 35	EF-06, 14	5, 6	Fuzzing d'entrées, charges SQL / XSS / CRLF, analyse statique
AC-18	SR-26, 37	EF-08, 09	3, 6	Images piégées et fuzzing du parseur : rejet $<$ 2 s, mémoire bornée
AC-19	SR-16, 28, 29	EF-12, 14	3, 5	Vérification hors ligne d'une livraison archivée ; événement d'ouverture
AC-20	SR-20, 22	EF-10, 13	3	Copie recadrée → « non concluant » (limite documentée, RR-01, RR-03)
AC-21	SR-31, 33, 35	EF-14, 17	5	Scénarios d'alertes ; injection CRLF dans le journal
AC-22	SR-34	EF-12	5	Réponses d'erreur uniformes ; absence de trace de pile
AC-23	SR-36, 37, 38	EF-08, 09	3, 7	Test de charge, quotas, requête surdimensionnée, restauration
AC-24	SR-23, 39, 40	Déploiement	7	Scan de secrets, d'images et de dépendances ; checklist de durcissement
AC-25	SR-06, 27	EF-03, 16	3	Inspection du stockage navigateur ; exportKey impossible

7 Gestion des exigences et évolution

Processus de changement. Toute modification passe par une issue GitHub (étiquette `requirement-change`) précisant la justification et l'impact sur AC, SR, EF et tests, puis par une pull request relue par l'autre membre. Chaque changement est daté dans l'historique des versions et le PDF est régénéré sous /docs. Les identifiants ne sont jamais réutilisés : une exigence abandonnée est marquée « retirée ». Version majeure : changement de périmètre ou d'architecture ; mineure : ajout ou modification d'exigences.

Jalon	Évolution attendue
Ch. 3 — CIA	Paramètres cryptographiques définitifs (tailles de marques, TLS) ; SR-15 à 24 affinées.
Ch. 4 — Authentification, autorisation	Politique de sessions et de mots de passe ; matrice RBAC finale ; revue de la minimisation des données.
Ch. 5 — Journalisation, erreurs	Liste définitive des événements d'audit et du format d'erreur (SR-31, 34, 35).
Ch. 6 — Tests de sécurité	Résultats, cas d'abus découverts, critères de vérification ajustés ; Should promus en Must si possible.
Ch. 7 — Déploiement	Durcissement, secrets, suivi des dépendances (SR-23, 39, 40).

Effet de l'ordre de coupe du cahier (§6.3). (1) Sans tableau de bord ni TOTP : SR-08 différée. (2) Sans filigrane : SR-20 limitée à l'empreinte. (3) CRL remplacée par une table de révocation interne : SR-17 s'applique à cette table. (4) Enrôlement par script : SR-06, 07 et 13 adaptées. Noyau jamais coupé : chiffrement de bout en bout et signature (SR-15, 16, 18), dissimulation (SR-21, 26), empreinte (SR-20, 22), autorisation (SR-09 à 12) et journal d'audit (SR-31).

Annexe A — Glossaire

Terme	Définition
AC	Cas d'abus (*abuse case*)
CIA	Confidentialité, intégrité, disponibilité
CRL	Liste de révocation de certificats
CSP	Content Security Policy
CSRF	Cross-Site Request Forgery
ECDH / ECDSA	Accord de clé / signature sur courbe elliptique (P-256)
HKDF	Dérivation de clé HMAC (RFC 5869)
HMAC	Code d'authentification de message à clé
IDOR	Accès direct non contrôlé à un objet
LSB	Bit de poids faible (stéganographie)
MoSCoW	Must, Should, Could, Won't
PoP	Preuve de possession de la clé privée
RBAC	Contrôle d'accès par rôles
SR / SRE	Exigence de sécurité / ingénierie des exigences de sécurité
SRI	Subresource Integrity